Creado por: vareCruzz
Nivel: Aprendiz | Categoría: Autenticación

INTRODUCCIÓN AL LABORATORIO

Este informe documenta paso a paso la resolución técnica del laboratorio **2FA Simple Bypass** de PortSwigger. El objetivo es vulnerar el mecanismo de autenticación de dos factores (2FA) de la aplicación web para acceder sin autorización a la cuenta del usuario `carlos`, careciendo por completo de acceso a su código de verificación dinámico.

CREDENCIALES PROPORCIONADAS

Rol / Entidad	Usuario	Contraseña	Acceso a Correo 2FA
Atacante (Cuenta de prueba)	`wiener`	`peter`	SÍ (Email Client)
Víctima (Objetivo)	`carlos`	`montoya`	NO

VECTOR PRINCIPAL DE VULNERABILIDAD

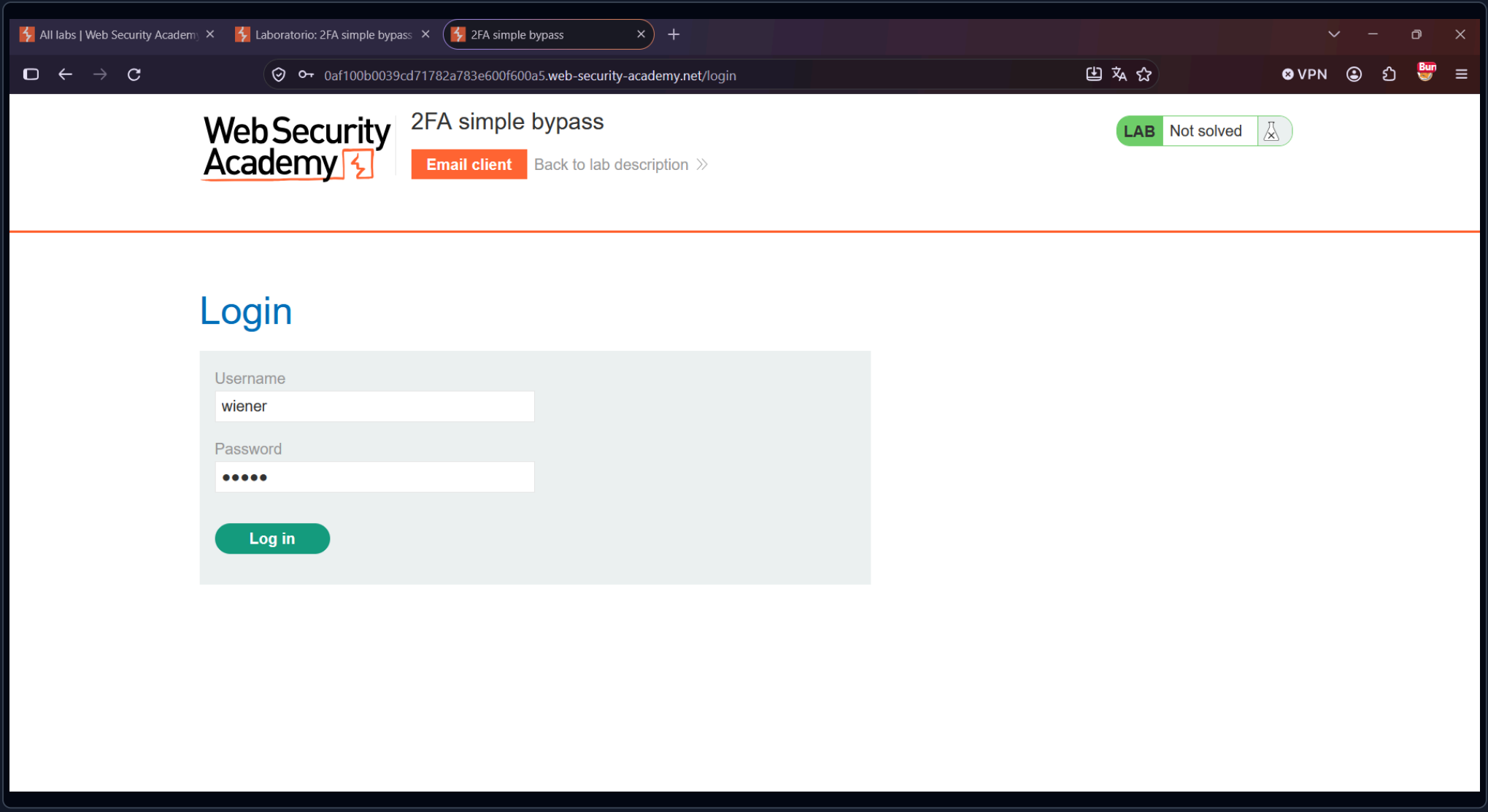
La falla reside en la **falta de validación del estado de 2FA** en las páginas protegidas tras enviar el primer factor. El servidor asigna la sesión de forma prematura al ingresar las credenciales correctas, permitiendo omitir la verificación del token de 4 dígitos mediante **Navegación Forzada (Forced Browsing / Direct URL Access)**.

01 Acceso a la pantalla del laboratorio en PortSwigger



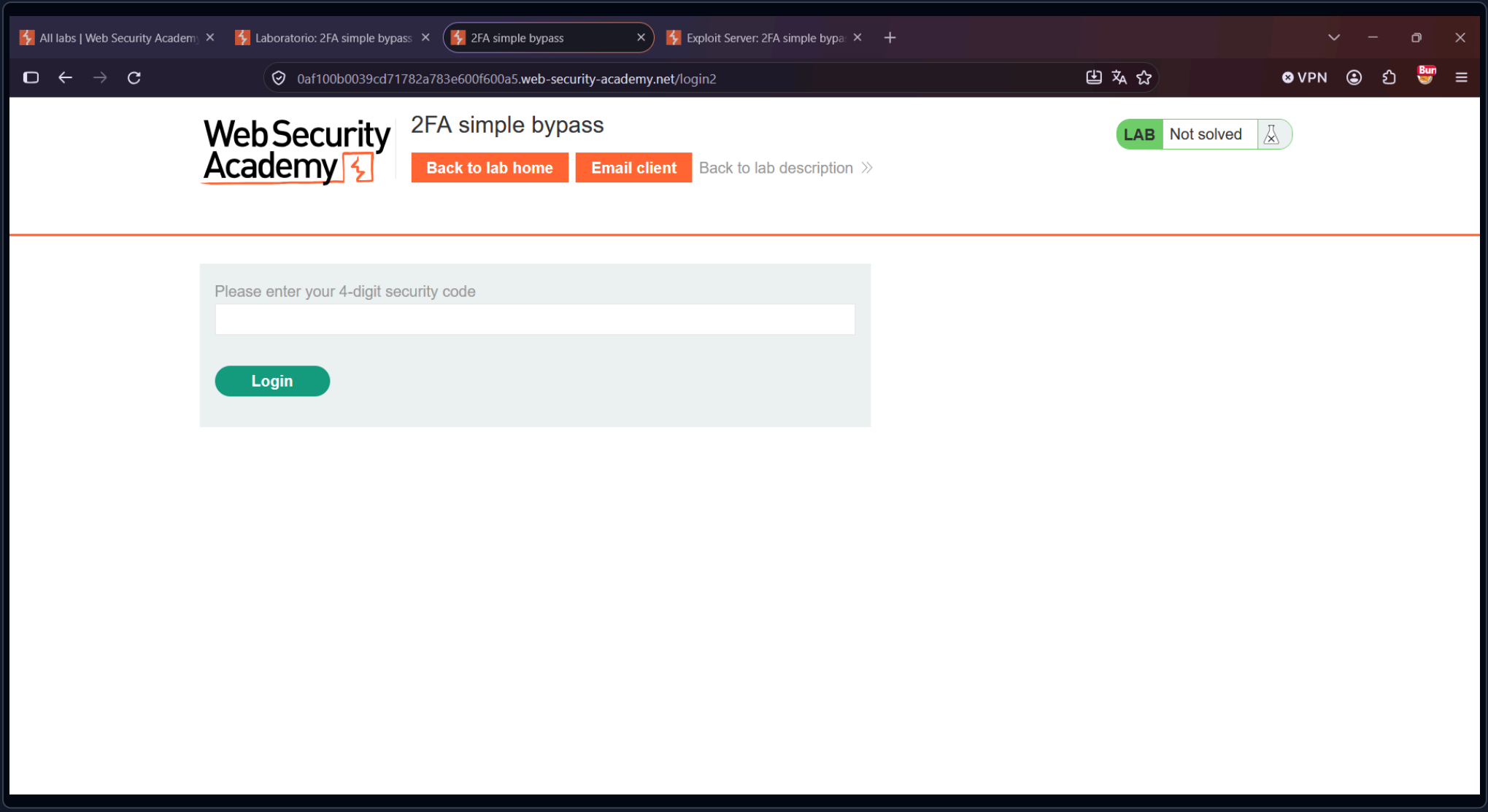
Análisis de la Captura: Se revisa la descripción original del ejercicio. La plataforma especifica las credenciales conocidas de `wiener:peter` y el objetivo del ataque: ingresar al panel de `carlos` sin poseer su código de seguridad de 4 dígitos.

02 Ingreso del primer factor (wiener:peter) en /login



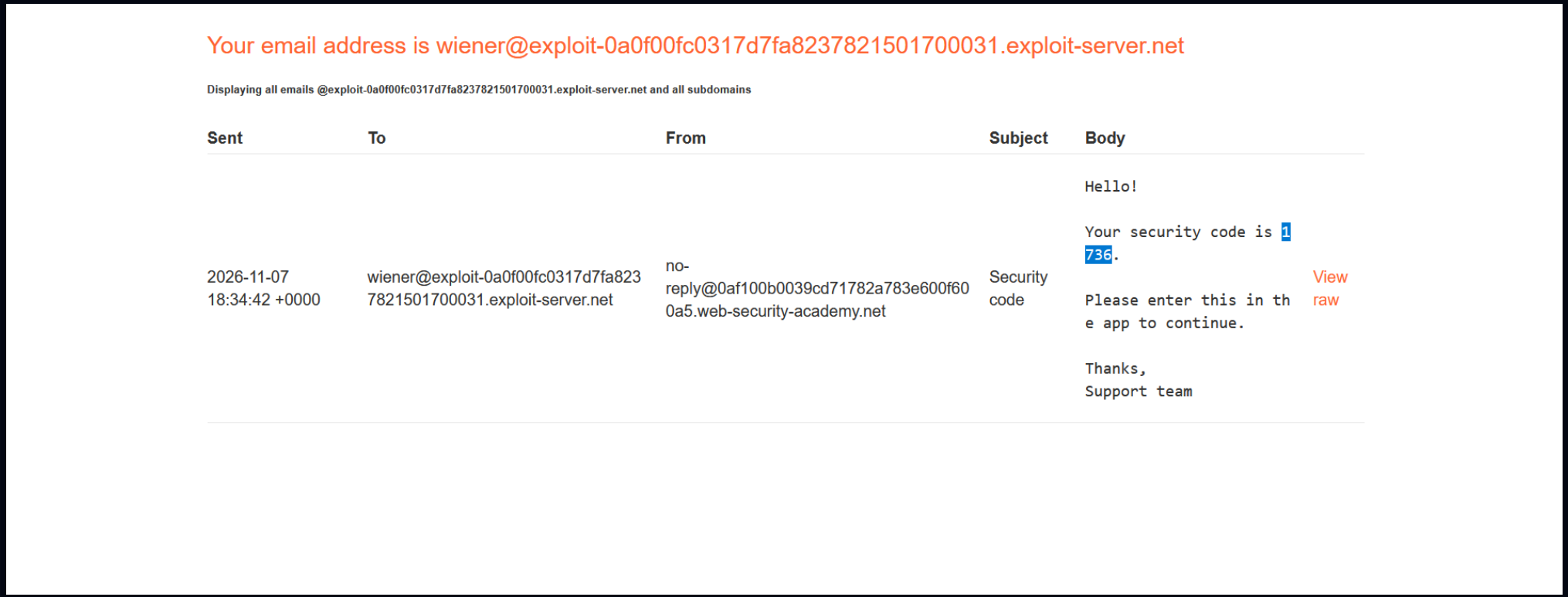
Análisis de la Captura: Iniciamos el recorrido legítimo enviando el usuario `wiener` y la clave `peter` en el endpoint `/login` para mapear la estructura de peticiones HTTP y cookies asignadas durante el proceso.

03 Llegada al formulario del segundo factor (/login2)



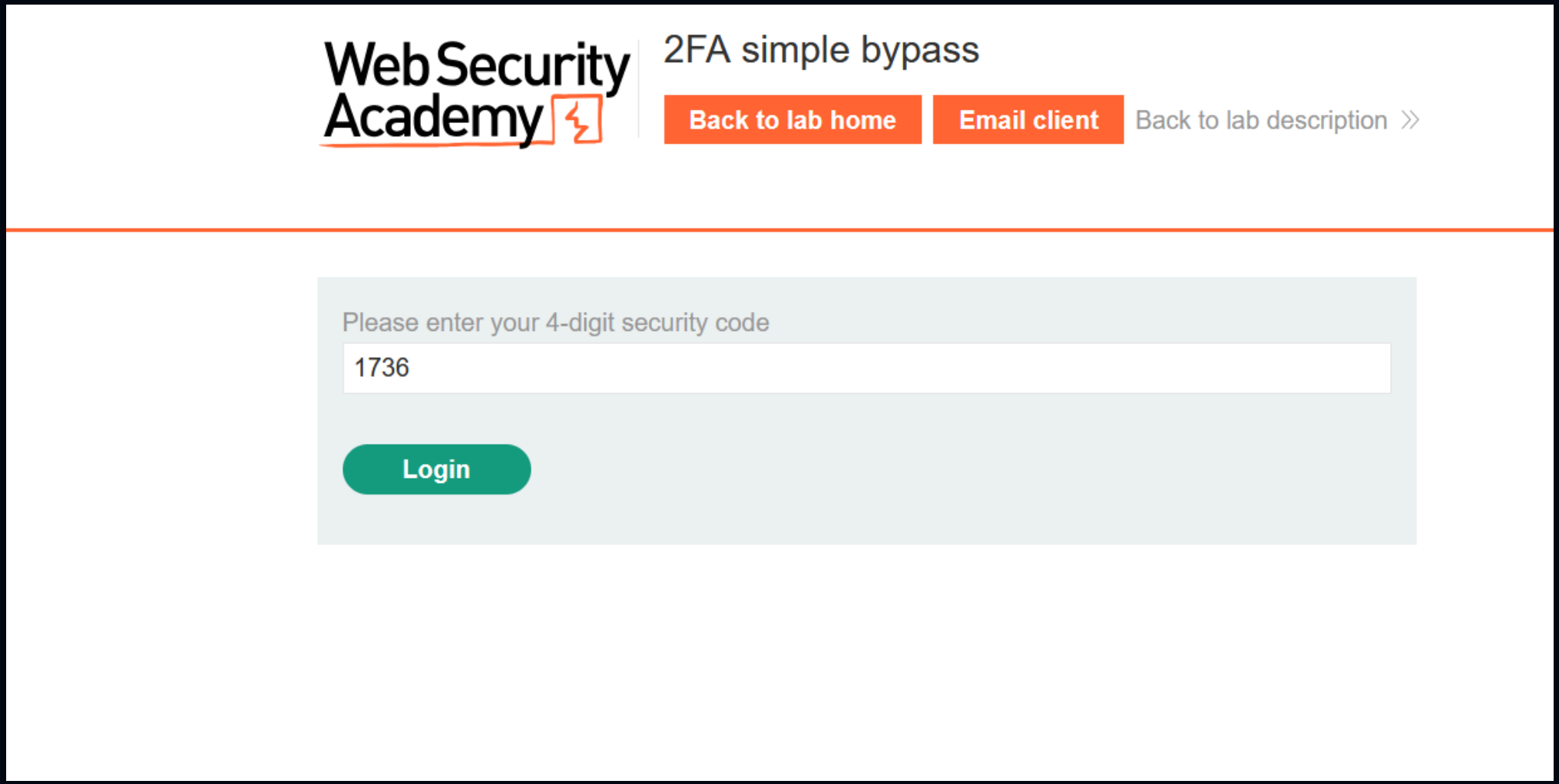
Análisis de la Captura: Tras validar la contraseña correcta, el servidor redirige automáticamente a la ruta `/login2`. Esta vista solicita ingresar un token temporal de 4 dígitos enviado a la casilla electrónica del usuario.

04 Lectura del token dinámico en el servidor de correo



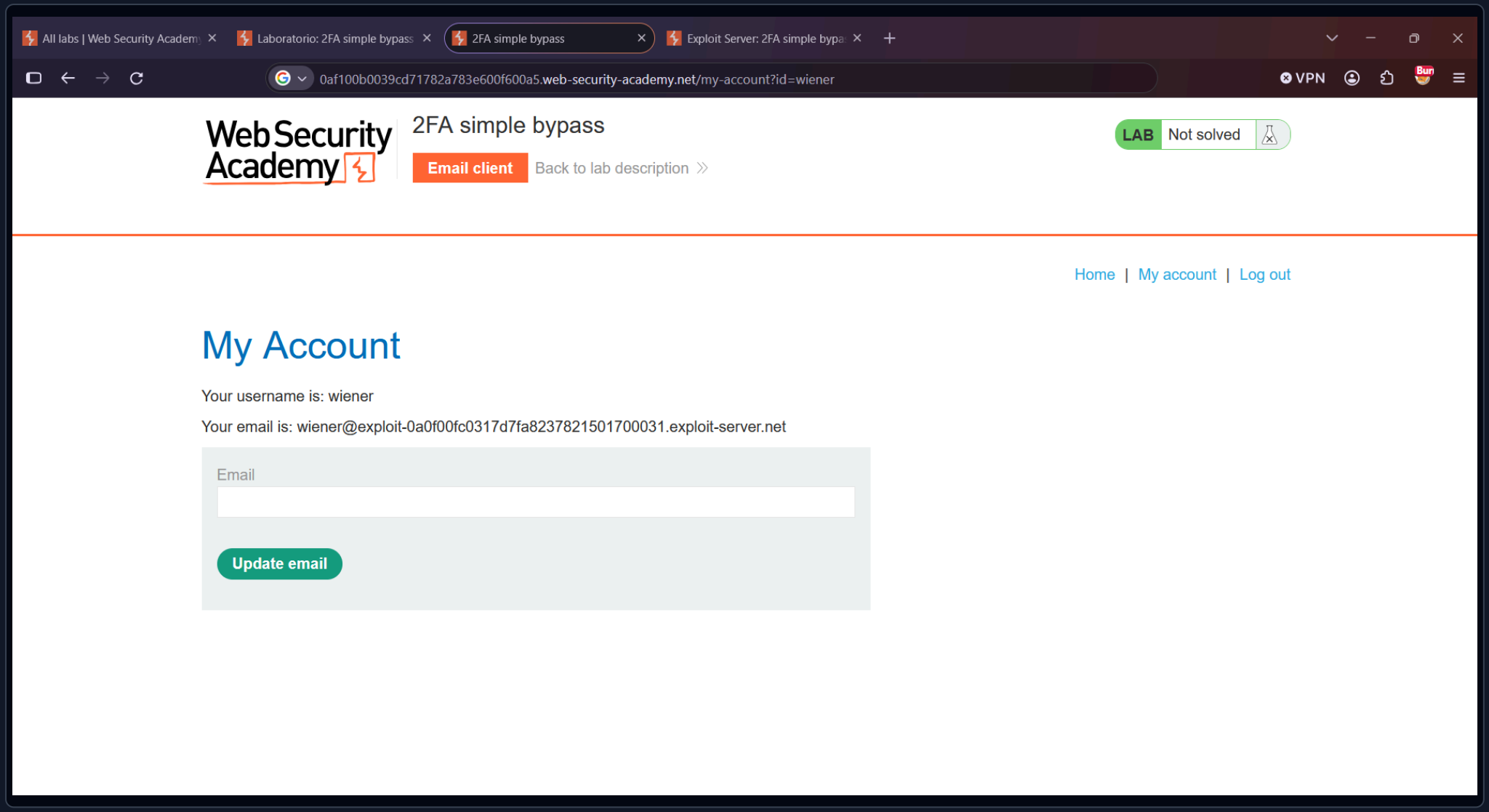
Análisis de la Captura: Abrimos el cliente de correo sintético (*Email client*) para la cuenta `wiener`. Constatamos la recepción de un correo remitido por `no-reply@...` que contiene el código de verificación: `1736`.

05 Ingreso del PIN 1736 en /login2



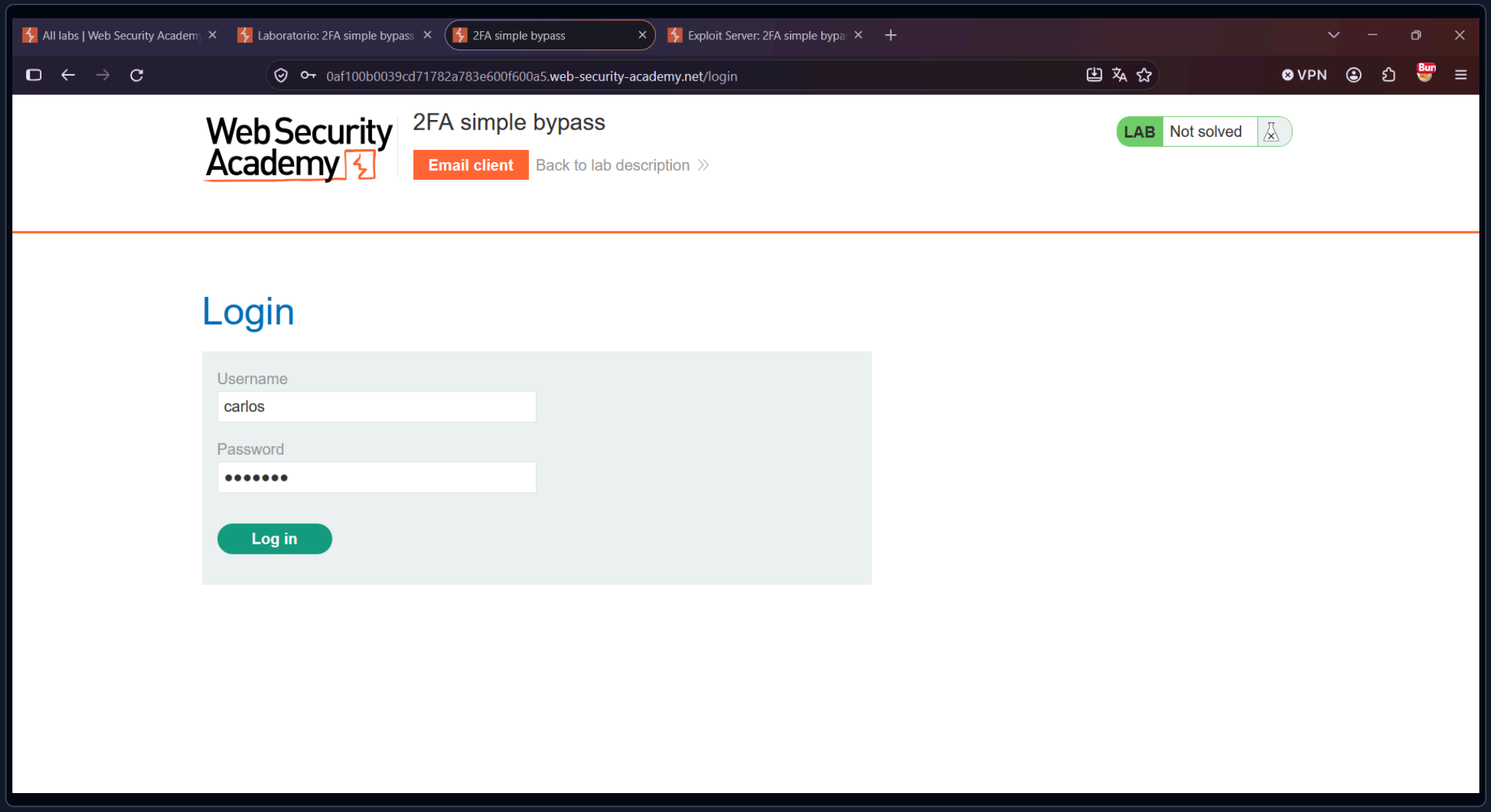
Análisis de la Captura: Rellenamos la casilla de verificación con el código `1736` y hacemos clic en el botón *Login* para enviar la solicitud POST de validación del segundo factor.

06 Acceso al panel /my-account?id=wiener



Análisis de la Captura: El servidor autentica la sesión por completo y nos dirige a `/my-account?id=wiener`. Hallazgo clave: la aplicación usa el parámetro GET `id` para cargar el perfil del usuario correspondiente.

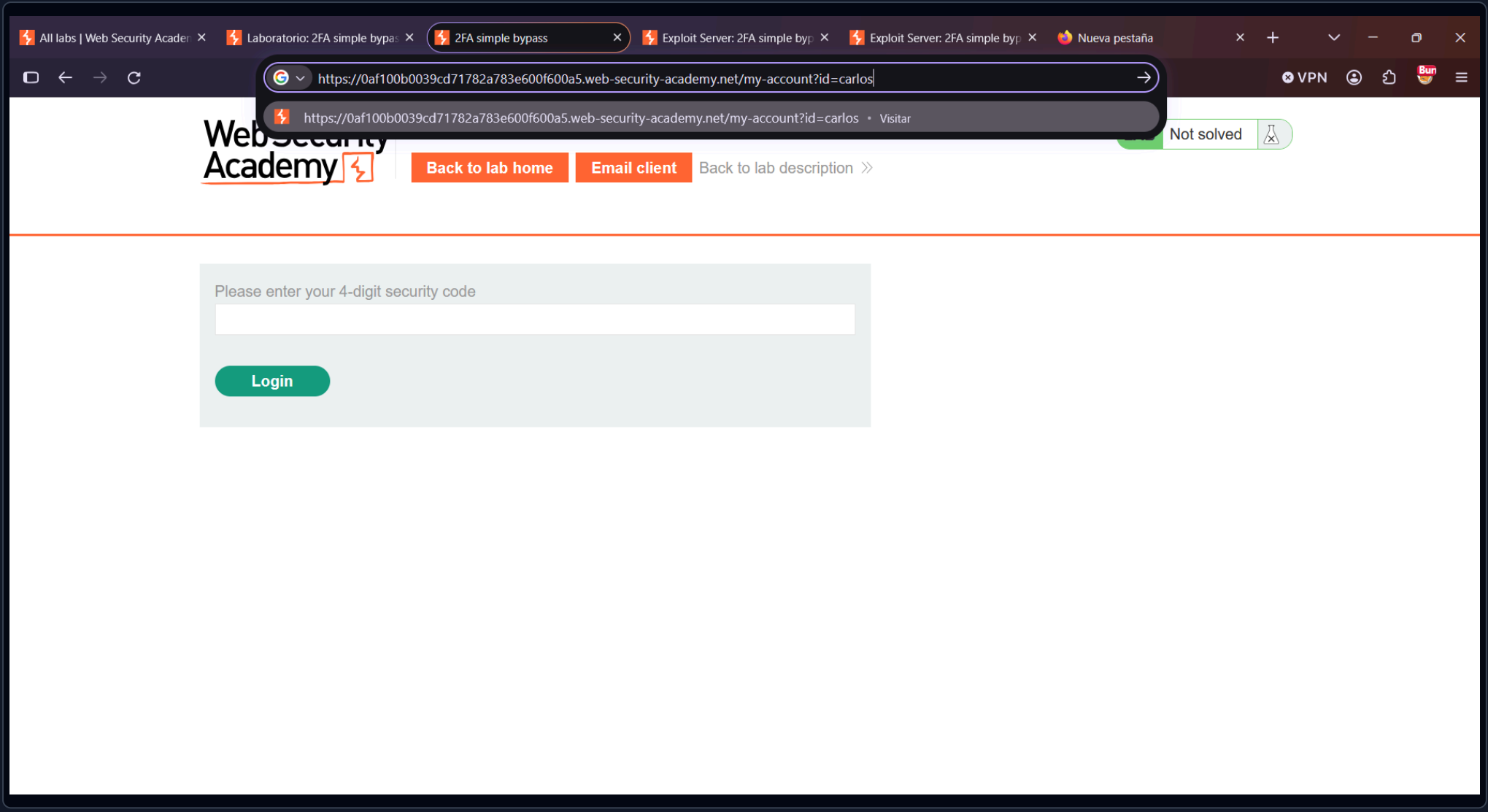
07 Ingreso del primer factor de Carlos (carlos:montoya)



Análisis de la Captura: Cerramos la sesión de prueba e iniciamos sesión con la víctima `carlos` y su contraseña `montoya`. Al dar clic en *Log in*, el sistema nos ubica en la pantalla 2FA `/login2` para exigir el código.

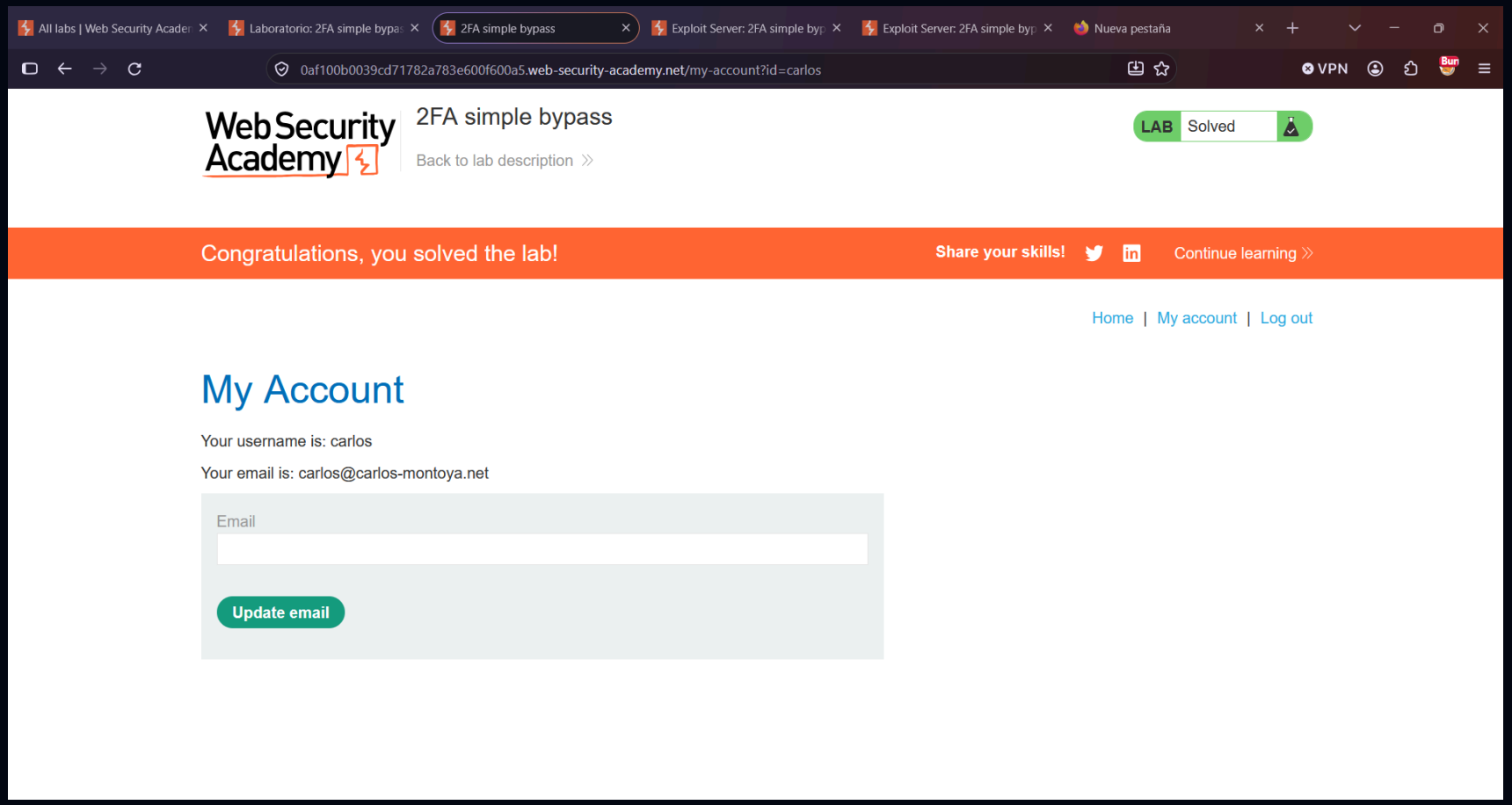
PASO 8: Ejecución del Bypass por Navegación Forzada

08 Modificación directa de la URL a /my-account?id=carlos



Análisis de la Captura: Sin introducir ningún código 2FA, reemplazamos manualmente la dirección del navegador por `https://.../my-account?id=carlos` y presionamos Enter para forzar el acceso directo a la vista del perfil.

09 Laboratorio resuelto e ingreso exitoso a la cuenta de Carlos



¿Por qué ocurrió esta vulnerabilidad? (Causa Raíz):

Esta vulnerabilidad sucede por una **falla crítica en el control de acceso y gestión de estado de autenticación (Broken Access Control / Broken Authentication)**:

- **Creación de sesión prematura:** El servidor genera la cookie de sesión autenticada inmediatamente al validar la contraseña (Paso 1), en lugar de marcarla como *"Sesión Parcial / Pendiente de 2FA"*.
- **Ausencia de middleware de verificación 2FA:** El recurso `/my-account` no valida si la cookie actual aprobó la verificación de `/login2`.
- **Confianza ciega en el flujo del cliente:** El desarrollador asumió que el usuario solo llegaría a `/my-account` mediante el botón de envío del 2FA, ignorando que la URL podía consultarse directamente.